Researching security ontologies for Information Systems

Roberto Monteiro Dias[1]
Sean Wolfgand Matsui Siqueira (Orientador) [1]

[1]Programa de Pós-Graduação em Informática (PPGI)
Universidade Federal do Estado do Rio de Janeiro (UNIRIO) - Rio de Janeiro – RJ

roberto.dias@edu.unirio.br,
sean@uniriotec.br

Abstract. *The increasing digitalization and interconnection of systems — such as Systems of Systems (SoS), Cyber-Physical Systems (CPS), and Intelligent Systems — driven by the use of APIs, have provided significant efficiency gains. However, this advancement has also expanded security vulnerabilities. To ensure secure communication that adheres to the principles of confidentiality, integrity, and availability, the use of ontologies is proposed as a strategic solution. Ontologies enable the integration of heterogeneous data and strengthen governance in complex and dynamic environments. This study conducts a Systematic Literature Review (SLR) with the aim of mapping the methods, techniques, and tools employed in the use of ontologies for security in Information Systems, considering the dimensions of Processes, People, and Technologies. As its main contribution, a multidimensional taxonomy will be developed, structured around these three dimensions and their respective subcategories, grounded in the research questions defined throughout this study.*

Abstract. *A crescente digitalização e interconexão de sistemas — como Sistemas de Sistemas (SoS), Sistemas Ciberfísicos (CPS) e Sistemas Inteligentes —, impulsionadas pelo uso de APIs, têm proporcionado ganhos expressivos de eficiência. No entanto, esse avanço também tem ampliado as vulnerabilidades de segurança. Para garantir uma comunicação segura, que observe os princípios de confiabilidade, integridade e disponibilidade, propõe-se o uso de ontologias como uma solução estratégica. Ontologias possibilitam a integração de dados heterogêneos e fortalecem a governança em ambientes complexos e dinâmicos. Este estudo realiza uma Revisão Sistemática da Literatura (RSL) com o objetivo de mapear os métodos, técnicas e ferramentas empregados no uso de ontologias voltadas à segurança em Sistemas de Informação, considerando as dimensões de Processos, Pessoas e Tecnologias. Como principal contribuição, será desenvolvida uma taxonomia multidimensional, estruturada com base nessas três dimensões e suas respectivas subcategorias, fundamentada nas questões de pesquisa delineadas ao longo deste estudo.*

Keywords: Information Security; Ontologies; Systems Integration; Systematic Review; Taxonomy.

1. Introdução

As grandes transformações no cenário econômico e social tornaram o gerenciamento da Segurança da Informação mais complexo. A intensa digitalização e interconexão de sistemas, impulsionadas pelo uso de *Interfaces de Programação de Aplicações* (do inglês, *Application Programming Interfaces* – APIs), evidenciaram a necessidade de integrar diferentes sistemas,

como *Sistemas de Sistemas* (SoS), *Sistemas Ciberfísicos* (CPS) e *Sistemas Inteligentes*. Essa integração, por sua vez, envolve frequentemente a colaboração entre diversas plataformas e serviços, ressaltando a crescente demanda por interconexão, interação e integração no contexto dos Sistemas de Informação (SI). Exemplos incluem os *Sistemas de Sistemas* (do inglês, *Systems-of-Systems* – SoS), os *Sistemas Ciberfísicos* (do inglês, *Cyber-Physical Systems* – CPS) e os *Sistemas Inteligentes* (do inglês, *Intelligent Systems*) [Maier 1998, Russell e Norvig 2010, Ghazani et al. 2012, Sommerville 2016b, Zeadally e Jabeur 2016].

Embora essa integração proporcione ganhos de eficiência e autonomia, ela também expõe vulnerabilidades de segurança nos sistemas interconectados. Diante desse cenário, torna-se fundamental adotar tecnologias que garantam uma comunicação segura entre os sistemas, atendendo a requisitos críticos como confiabilidade, integridade e disponibilidade da informação. A dificuldade dos gestores de TI em lidar com esses aspectos pode aumentar a exposição a ameaças e os impactos decorrentes de ataques cibernéticos.

Nesse contexto, é essencial implementar mecanismos e tecnologias que assegurem que a comunicação entre sistemas seja tratada sob a perspectiva da segurança da informação, abrangendo os princípios de confidencialidade, integridade e disponibilidade [ISO 2013]. Considerando esses desafios, o uso de ontologias no domínio da segurança da informação surge como uma solução estratégica, capaz de superar a heterogeneidade de dados, mitigar ambiguidades conceituais e fortalecer a governança da informação em ambientes compostos por sistemas complexos.

Diante disso, este estudo propõe a realização de uma revisão sistemática da literatura com o objetivo de compreender como a academia tem abordado o desenvolvimento e a aplicação de ontologias de segurança em SI. A análise permitirá identificar métodos, técnicas, modelos e ferramentas empregados, avaliar seus desempenhos e mapear componentes impactantes, considerando as três dimensões dos SI: **Processos**, **Pessoas** e **Tecnologias**. Como resultado, pretende-se desenvolver uma taxonomia genérica para estruturar as abordagens existentes, proporcionando uma visão holística sobre o uso de ontologias de segurança em Sistemas de Informação.

Este artigo está estruturado da seguinte maneira: na Seção 2, são abordados os estudos relacionados. A Seção 3 traz a fundamentação teórica que sustenta a pesquisa. Na Seção 4, são apresentados o planejamento e a execução do estudo. Os resultados, juntamente com a análise e as limitações, são discutidos na Seção 5. Por fim, a conclusão é apresentada na Seção 6.

2. estudos Relacionados

Na literatura atual, encontramos uma variedade de estudos relacionados. Dentre eles, pode-se destacar os estudos de Park e Lee (2022) , Hongyi *et al.* (2023) e Lam *et al.* (2024) .

Para Park e Lee (2022), ataques que causam impactos comerciais são mais inteligentes e complexos, pois assumem a forma de vários elementos de ataque. Eles identificaram que ataques de ameaça persistente avançada (do inglês, Advanced Persistent Threat ou APT) refletem essa característica. Além disso, mencionaram que métodos de gerenciamento de risco podem ser utilizados para gerenciar a segurança em SI das organizações. No entanto, esses métodos enfrentam dificuldades para responder ativamente a esses ataques devido às limitações das atividades de avaliação qualitativa orientadas por ativos. Como solução, eles apresentam uma ontologia de domínio de segurança para Problemas com Consciência de Riscos, especializada em avaliação de risco de APT, consistindo em componentes de ataque, componentes de risco, componentes de requisitos de segurança e um componente de mitigação.

Hongyi *et al.* (2023) apontam que as atividades de ataque cibernético são complexas e estão em constante mudança. Por isso, eles expandiram a ontologia UCO (Upper Cybersecurity Ontology), além de desenvolver uma nova ontologia específica, baseada nas características adequadas para o conjunto de dados CS13K, mas com a reutilização de outras ontologias de segurança existentes. Eles também aproveitaram a ontologia estendida por meio da ferramenta *Neo4j* [1] para construir um gráfico de conhecimento de segurança cibernética, que ajuda na identificação de ameaças e na consciência situacional nas organizações.

Lam *et al.* (2024) desenvolveram o sistema de Análise e Reconhecimento Automático Verificável de Linguagem para Entradas (do inglês, Verifiable Automatic Language Analysis and Recognition for Inputs ou VALARIN), que analisa divergências entre diferentes analisadores de PDF para identificar e classificar erros, auxiliando na detecção de vulnerabilidades. Uma ontologia do domínio de segurança em SI foi desenvolvida, para permitir a representação estruturada de informações e o raciocínio automatizado. Os erros são classificados em uma ontologia hierárquica, facilitando sua identificação e categorização. O sistema VALARIN integra essa ontologia para fornecer insights sobre os erros, enquanto o editor de ontologias *Protégé* [2] é utilizado para desenvolvê-la. Analisadores de PDF, como xpdf, pdfbox, mutool e poppler, são empregados para extrair informações e gerar relatórios de erros.

Desse modo, estes estudo corroboram com a importância da ontologia de segurança da informação em SI.

3. Fundamentação Teórica

3.1. Ontologia

Define-se **ontologia**, no âmbito da Ciência da Computação, como uma representação formal e explícita de um conjunto de conceitos dentro de um domínio específico, bem como das relações existentes entre esses conceitos, com o objetivo de possibilitar o compartilhamento, a reutilização e a interoperabilidade do conhecimento entre sistemas heterogêneos [Noy e Mcguinness 2001]. Ela fornece uma estrutura comum que permite que diferentes agentes — humanos ou computacionais — compreendam e manipulem informações de maneira consistente. Seu uso é especialmente relevante em áreas como a engenharia do conhecimento, integração de dados, recuperação da informação e, particularmente, na modelagem de domínios complexos, como os SI e a Segurança da Informação. Ao estabelecer uma semântica compartilhada, as ontologias promovem a consistência terminológica, a automatização de processos e a melhoria da qualidade das informações tratadas pelos sistemas em SI [Studer et al. 1998].

3.2. Segurança da Informação

Whitman e Mattord (2009) definem **segurança da informação** (InfoSec, do inglês *Information Security*) como a proteção da informação e seus elementos críticos, incluindo os sistemas e hardware que usam, armazenam e transmitem essa informação. Também identificam várias características críticas da informação que lhe conferem valor nas organizações. Essa definição está relacionada como a preservação da **C**onfidencialidade, **I**ntegridade e **D**isponibilidade de informações (tríade CID) [Malagutti 2016]. A norma internacional ISO/IEC 27002:2013 [ISO 2013] enfatiza que segurança da informação é alcançada por meio da implementação de um conjunto adequado de controles, incluindo políticas, processos, procedimentos, estrutura organizacional e funções de software e hardware. Estes controles precisam ser estabelecidos, implementados,

[1] https://neo4j.com/
[2] https://protege.stanford.edu/

monitorados, analisados criticamente e melhorados, quando necessário, para assegurar que os objetivos do negócio e a segurança da informação da organização sejam atendidos.

3.3. Taxonomia

A taxonomia constitui-se como um **sistema de classificação sistemático**, estruturando o conhecimento em categorias hierárquicas com três finalidades principais: (1) organizar conceitualmente o universo informacional; (2) padronizar a comunicação especializada; e (3) otimizar os processos de armazenamento e recuperação da informação [Brasileiro et al. 2019]. Etimologicamente, o termo origina-se do grego antigo, combinando *taxis* (ordenação) e *nomos* (norma), refletindo sua essência como uma técnica de sistematização do conhecimento [Brasileiro et al. 2019]. Embora seu uso mais conhecido ocorra na biologia — na classificação de organismos vivos —, sua aplicação estende-se a diversos domínios, desde a ciência da informação até a gestão do conhecimento em ambientes corporativos em SI. A taxonomia mantém sua relevância, especialmente nas organizações modernas, por ser amplamente utilizada na estruturação de dados, na gestão do conhecimento e na melhoria da recuperação da informação em SI. [Campos e Gomes 2008] [Aganette et al. 2010]. Em um mundo marcado pelo excesso de informações, as taxonomias surgem como soluções práticas para a organização e recuperação de dados, alinhando-se tanto aos objetivos institucionais quanto às necessidades dos usuários [Brasileiro et al. 2019]. Sua flexibilidade e abordagem sistemática tornam-na indispensável tanto para a ciência quanto para a gestão do conhecimento corporativo em SI [Campos e Gomes 2008] [Aganette et al. 2010].

4. Revisão Sistemática da Literatura

Este Método de Pesquisa foi realizado com o objetivo de investigar as ontologias de segurança da informação, visando obter um melhor entendimento de como esse tema é abordado na literatura científica, considerando o contexto, o domínio e os tipos de soluções aplicadas em SI. A partir das diretrizes de [Kitchenham e Charters 2007], foi elaborado um protocolo para execução da revisão sistemática, composto pelas seguintes fases: (1) Planejamento, (2) Execução e (3) Apresentação dos Resultados.

4.1. Planejamento

4.1.1. Questão de Pesquisa

Visando expressar os objetivos deste estudo, a questão de pesquisa (QP) foi formulada seguindo os critérios especificados no PIO (***Population, Intervention e Outlines)***, como pode ser visto na Tabela 1.

Tabela 1. Critérios de PIO

Population	Segurança da Informação e Sistemas de Informação
Intervention	Métodos, Técnicas, Tecnologias, Ferramentas
Outcome	Métodos, Técnicas, Tecnologias, Ferramentas
Context	Estudos Primários

Com isso, foi formulada a seguinte questão de pesquisa (***QP)***:

QP: *Como as ontologias de segurança têm sido utilizadas no contexto de SI?*

Para ajudar a responder a ***QP***, também foram elaboradas as seguintes subquestões ***(Sub-Q)*** (ver Tabela 2):

Tabela 2. Subquestões de Pesquisa

ID	Subquestão de Pesquisa
Sub-Q1	Quais métodos, técnicas, modelos e ferramentas são utilizados em ontologias de segurança, considerando tecnologia, processos e pessoas em SI?
Sub-Q2	Como é avaliado o desempenho dessas ontologias de segurança considerando as três dimensões de SI?
Sub-Q3	Quais componentes impactam o desenvolvimento e aplicação dessas ontologias em cada dimensão de SI?

4.1.2. Fontes de Busca:

As buscas eletrônicas foram realizadas na base Scopus[3] e nas bibliotecas digitais ACM Digital Library[4], IEEE Xplore[5], Science Direct[6] e Springer Link[7]. Essas bases de dados foram escolhidas, pois armazenam um grande volume de estudos científicos relevantes da área de Ciência da Computação, seguindo as recomendações de Dyba et al. (2007).

4.1.3. Definição dos Termos de Pesquisa:

Para a pesquisa nas bases de dados definidas, foi criada uma *string* de busca com a junção dos termos e sinônimos, que representam a população e a intervenção que compõem os critérios PIO apresentados na Tabela 1. Após a realização de alguns testes, chegou-se à seguinte *string* de busca:

*("**Domain ontology**" AND "**information security**")*

4.1.4. Critérios de Seleção dos Estudos:

A Tabela 3 descreve os critérios de inclusão (CI) e exclusão (CE) aplicados sobre os estudos retornados pela *string* de busca, conforme Kitchenham e Charters [Kitchenham e Charters 2007].

[3]https://www.scopus.com/
[4]https://dl.acm.org/
[5]https://ieeexplore.ieee.org/Xplore/home.jsp
[6]https://www.sciencedirect.com/
[7]https://ihttps://link.springer.com/

Tabela 3. Critérios de Seleção

Categoria	Código	Descrição
Critérios de Inclusão		
	CI1	Estudos com acesso disponível.
	CI2	Estudos que abordam ontologias de segurança em SI.
	CI3	Estudos publicados depois de 2019.
Critérios de Exclusão		
	CE1	Estudos com leitura integral bloqueada.
	CE2	Estudos como artigos curtos ou pôsteres.
	CE3	Estudos duplicados e/ou que reportam resultados de outro estudo (neste caso, será considerado o estudo mais atual para a análise).
	CE4	Estudos que não estão escritos em inglês.
	CE5	Estudos que não abordam o tema.
	CE6	Estudos que não respondem a pelo menos uma das perguntas de pesquisa.
	CE7	Estudos publicados antes de 2019.

4.2. Execução

4.2.1. Processo de Seleção dos Estudos

A Figura 1 mostra o processo de seleção dos estudos, e a quantidade de estudos excluídos e motivo em cada etapa.

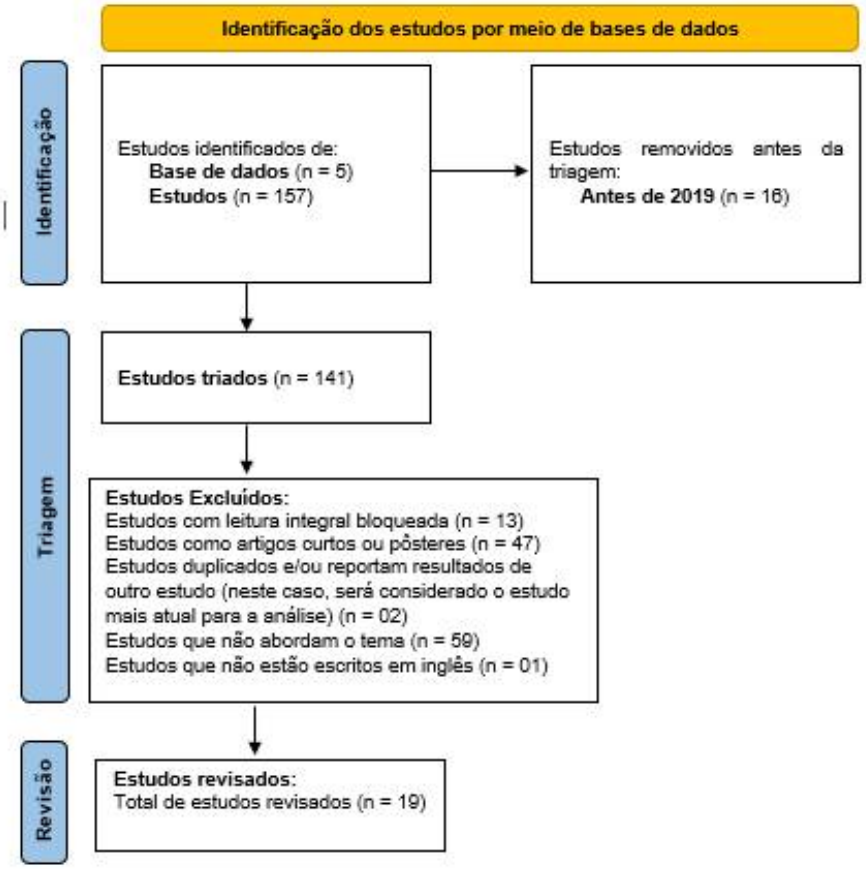


Figura 1. Processo de seleção de estudos.

O processo de seleção será composto por quatro etapas:

- **Identificação:** Nesta etapa, realizou-se a busca e exclusão de estudos publicados antes de 2019. A escolha deste corte temporal, abrangendo os últimos cinco anos, se justifica pela rápida evolução das tecnologias na área de Ciência da Computação. Estudos anteriores a essa data podem não refletir as tendências, avanços e práticas atuais, tornando-se, portanto, menos relevantes para nossa análise.
- **Triagem:** Esta fase consiste na avaliação dos estudos para garantir que se enquadrem nos critérios de inclusão e exclusão previamente estabelecidos.
- **Revisão:** Envolve uma análise detalhada e avaliação crítica dos estudos selecionados, visando extrair informações relevantes para nossa pesquisa.

O processo de seleção dos estudos foi executado nas bases na última semana mês de setembro de 2024 e a filtragem dos resultados ocorreu em 3 etapas.

Na etapa 1, foi executada a busca eletrônica com a string de pesquisa nas bases selecionadas, sendo retornados o total de 157 estudos. Esses estudos foram armazenados na ferramenta Parsifal[8], que facilita a organização, filtragem, categorização e revisão dos estudos, para execução das demais etapas.

Na etapa 2, foram excluídos os seguintes tipos de estudos: aqueles com leitura integral bloqueada (13 estudos), artigos curtos ou pôsteres (47 estudos), estudos duplicados ou que reportam resultados de outros estudos (2 estudos), estudos que não abordam o tema central (59 estudos) e, por último, estudos que não estão escritos em inglês (1 estudo).

Por fim, na etapa 3, foram selecionados 19 estudos para a análise de dados e a coleta de respostas às questões de pesquisa.

4.3. Levantamento de Dados

Foram selecionados 19 estudos sobre ontologias de segurança em Sistemas de Informação, os quais apresentam uma variedade de métodos, técnicas, modelos e ferramentas.
Esses estudos também abordam o desempenho das ontologias e os componentes que impactam seu desenvolvimento e aplicação, conforme apresentado na Tabela 4 [Szyperski 2002] [Sommerville 2016a].
A tabela está organizada em colunas que indicam o ID, título, autores e ano de publicação de cada estudo, de forma a facilitar a identificação e análise das referências selecionadas.

O processo de extração, conforme citado acima, foi realizado sistematicamente, com o auxílio da ferramenta Parsifal para o registro de informações necessárias para responder às questões de pesquisa.

5. Apresentação dos resultados

Foram selecionados 19 estudos sobre ontologias de segurança em Sistemas de Informação, os quais apresentam uma variedade de métodos, técnicas, modelos e ferramentas. Esses estudos também abordam o desempenho das ontologias e os componentes que impactam seu desenvolvimento e aplicação, conforme apresentado na Tabela 4 [**?**][Sommerville 2016a].

A tabela 4 está organizada em colunas que indicam o ID, título, autores e ano de publicação de cada estudo, de forma a facilitar a identificação e análise das referências selecionadas.

[8]https://parsif.al/

5.1. Dados demográficos

A **Figura** 2 apresenta a cronologia dos 19 estudos selecionados. Em 2020, não houve publicações, possivelmente em decorrência dos impactos iniciais da pandemia e das medidas de lockdown. No entanto, em 2021, as publicações foram retomadas, indicando uma adaptação ao novo cenário.

A partir de 2022, registrou-se um crescimento acentuado no número de publicações, reflexo das transformações tecnológicas aceleradas pela pandemia. Esse fenômeno não apenas evidenciou a maior relevância do tema, mas também impulsionou o interesse e o incentivo à pesquisa na área.

Assim, a **Figura** 3 ilustra uma mudança no paradigma da produção científica, com países emergentes assumindo um papel mais ativo nas publicações sobre segurança em SI. Essa tendência reforça o crescente engajamento global em torno do assunto.

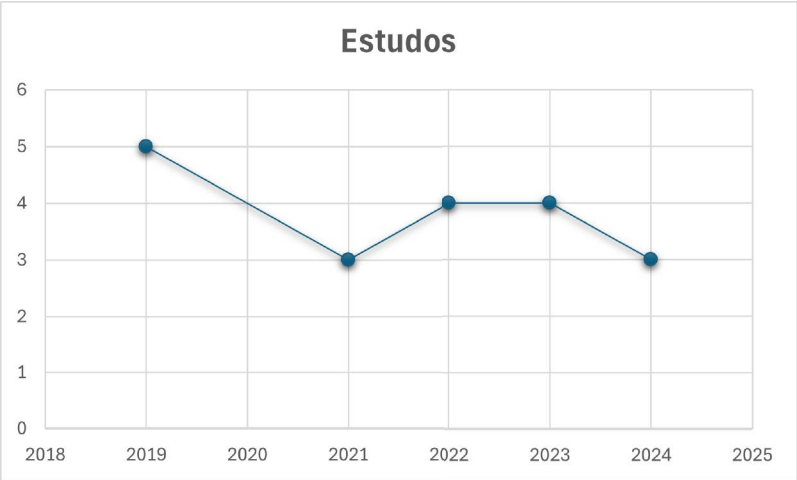


Figura 2. Quantidade de estudos publicados por ano.

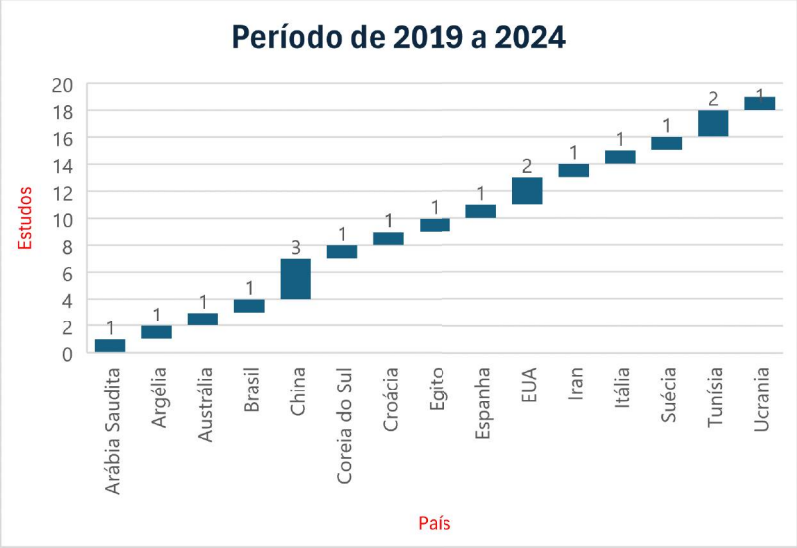


Figura 3. Quantidade de estudos publicados por país.

Tabela 4. Dados extraídos dos estudos selecionados

ID	Título	Autores	Ano
E1	A First Step Towards an ISO-Based Information Security Domain Ontology	Casola, V., Catelli, R., De Benedictis, A.	2019
E2	STRAM: Measuring the Trustworthiness of Computer-Based Systems	Cho, Jin-Hee, Xu, Shouhuai, Hurley, Patrick M., Mackay, Matthew, Benjamin, Trevor, Beaumont, Mark	2019
E3	An Ontology-Based Model for User Profile Building Using Social Networks	Niyazova, R., Aktayeva, A., Davletkireeva, L.	2019
E4	Comparative Study of Ontologies Based on ISO 27000 Series Security Standards	Meriah, I., Ben Arfa Rabai, L.	2019
E5	An ontology-driven framework for knowledge representation of digital extortion attacks	Keshavarzi, M., Ghaffary, H. R.	2019
E6	Ontology-Based Approach to Validation of Learning Outcomes for Information Security Domain	Rogushina, J. V., Gladun, A. Y., Pryima, S. M., Strokan, O. V.	2019
E7	Applying Multi-Level Theory to an Information Security Incident Domain Ontology	Faria, M. R., Botelho de Figueiredo, G., de Faria Cordeiro, K., Reis Cavalcanti, M. C., Campos, M. L. M.	2019
E8	Social Engineering in Cybersecurity: A Domain Ontology and Knowledge Graph Application Examples	Wang, Z., Zhu, H., Liu, P., Sun, L.	2019
E9	Towards an Automatic Approach to the Design of A Generic Ontology for Information Security	Meriah, I., Rabai, L. B. A., Khedri, R.	2021
E10	A Combined Security Ontology Based on the Unified Foundational Ontology	Adach, M., Hänninen, K., Lundqvist, K.	2022
E11	Threat-Driven Risk Assessment for APT Attacks Using Risk-Aware Problem Domain Ontology	Park, S.-H., Lee, S.-W.	2022
E12	Multiontology Construction and Application of Threat Model Based on Adversarial Attack and Defense Under ISO/IEC 27032	Hu, X., Cheng, D., Chen, J., Jin, X., Wu, B.	2022
E13	A Framework for Conceptual Characterization of Ontologies and Its Application in the Cybersecurity Domain	Martins, B. F., Serrano Gil, L. J., Reyes Román, J. F., Panach, J. I., Pastor, Ó., Hadad, M., Rochwerger, B.	2022
E14	Ontology-Based Cybersecurity for Well-Being, Aging and Health: A Scoping Review	Belani, H., Šolić, P., Perković, T., Zovko, K.	2023
E15	APKOWL: An Automatic Approach to Enhance the Malware Detection	Aboshady, D., Ghannam, N. E., Elsayed, E. K., Diab, L. S.	2023
E16	Cybersecurity Knowledge Graphs	Sikos, L. F.	2023
E17	PDF Investigation With Parser Differentials and Ontology	Lam, Denley, Li, Letitia, Anderson, Cory	2024
E18	Integrated Interaction Journey and Privacy Risk Assessment: A Graph Model	Alabsi, M., Gill, A., Bandara, M.	2024
E19	Cybersecurity Knowledge Graphs Construction and Quality Assessment	Li, H., Shi, Z., Pan, C., Zhao, D., Sun, N.	2024

5.2. Limitações

Este estudo apresenta algumas limitações, como, por exemplo, a string de busca, pode ter limitado o número de estudos retornados. Além disso, bases como Scopus e ACM Digital Library apresentaram estudos bloqueados. Dessa forma, este estudo pode ser expandido no futuro com uma string de busca mais ampla e com maior acesso a essas respectivas bases.

5.3. Análise dos Resultados

Para responder à QP, os dados coletados foram analisados com base nas respostas das **Sub-Q**:

***Sub-Q1**: Quais métodos, técnicas, modelos e ferramentas são utilizados em ontologias de segurança, considerando as dimensões fundamentais em SI?*

A análise dos estudos evidencia que a aplicação de ontologias de segurança em SI se estrutura com base em três dimensões fundamentais: **Processos**, **Pessoas** e **Tecnologias** [Laudon e Laudon 2020].

Na dimensão dos **Processos**, dois eixos principais se destacam:

- **Análise e avaliação de riscos**: Representada pelo estudo **E1**, que é uma base fundamental em um Sistema de Gestão de Segurança da Informação (SGSI), vinculando-a diretamente aos requisitos da norma ISO/IEC 27001 e aos processos de verificação de controles de segurança. O estudo **E2** também estabelece a análise de riscos como metodologia essencial para mensuração da confiabilidade de sistemas. Já o estudo **E4** propõe a utilização de ontologias de segurança, relacionadas à ISO 27005, como um processo de avaliação e tratamento de riscos, enquanto o estudo **E10** desenvolve este processo por meio da Ontologia de Segurança Combinada (do inglês, *Common Security Ontology* ou **CSO**), que operacionaliza o conceito de risco com base em padrões reconhecidos, como o NIST SP 800-30. O estudo **E11** propõe um modelo específico para avaliação de riscos relacionados a ataques APT (*Advanced Persistent Threat*), integrando requisitos de segurança e componentes de risco. Paralelamente, o estudo **E13** emprega a norma ISO/IEC 27005:2011 como *framework* para gestão de riscos, realizando uma análise conceitual detalhada do risco no contexto da cibersegurança. O estudo **E18** apresenta uma contribuição aplicada para avaliação de riscos de privacidade baseada no NIST 800-30, com implementação prática em ambientes de aeroportos inteligentes.
- **Modelagem de ontologias**: O estudo **E1** apresenta um modelo baseado em ontologia para gestão de documentos em Sistemas de Gestão de Segurança da Informação (SGSI), com duas camadas de abstração ontológica, detalhando o uso da ferramenta Protégé para modelagem de uma ontologia de segurança da informação alinhada à ISO. O estudo **E5** descreve o design e a implementação da ontologia dedicada ao domínio das chantagens digitais, denominada **Rantology**, voltada para ataques de extorsão digital, utilizando uma abordagem iterativa de sete passos e sendo expressa em OWL. O estudo **E8** apresenta o processo de definição de relações em uma ontologia de domínio, com implementação no Protégé e exportação para o Neo4j para construção de grafo de conhecimento. Já o estudo **E9** propõe um método automático para o design de uma ontologia genérica de segurança da informação, com etapas que envolvem a coleta automatizada de dados online (web scraping), classificação de conceitos e processos de design manual, semiautomático e automático. O estudo **E10** discute a implementação da CSO, utilizando diagramas UML e metodologias como CommonKADS e Methontology. O estudo **E12** detalha a construção de uma estrutura multi-ontológica composta por três camadas: ontologia generalizada, ontologia de domínio (ataque e defesa) e ontologia de aplicação (baseada em padrões como ISO/IEC 27032 e MITRE ATT&CK). A interconexão dessas ontologias permite uma modelagem de ameaças sistemática e orientada por conhecimento, que aprimora a análise de cenários adversariais e a identificação de falhas de segurança. O estudo **E15** apresenta o método denominado **APKOWL** para a construção automática de uma ontologia em OWL (Web Ontology Language) que modela a estrutura de malwares. Por fim, o estudo **E17** descreve o desenvolvimento de uma ontologia em OWL para programas projetados para interpretar o conteúdo de um arquivo PDF (Portable Document Format).

Na dimensão das **Pessoas**, destacam-se ontologias de segurança com **aplicações práticas em cenários reais**, com foco no comportamento, perfil e bem-estar dos usuários. Os estudos analisados evidenciam diferentes formas de aplicação dessas ontologias. O estudo **E5** utiliza a ontologia *Rantology* para reforçar a segurança digital dos usuários, reduzindo o impacto de ataques cibernéticos direcionados. No estudo **E8**, é proposta uma ontologia de domínio voltada à engenharia social, aplicada à análise de cenários reais por meio de grafos de conhecimento. Essa abordagem permite mapear o ciclo de ataques que exploram vulnerabilidades humanas — como confiança e curiosidade — contribuindo para a prevenção e educação dos usuários. No estudo **E15**, o sistema *APKOWL* emprega uma ontologia em OWL gerada automaticamente para detectar malware SMS em aplicativos Android. A técnica de engenharia reversa possibilita a compreensão do comportamento e da estrutura desses aplicativos, auxiliando na definição de perfis de uso e na identificação de ameaças. O estudo **E17** apresenta o sistema *VALARIN*, voltado à análise de arquivos PDF com o objetivo de detectar características maliciosas. Essa solução é especialmente relevante para usuários que lidam rotineiramente com documentos digitais, oferecendo proteção contra ameaças comuns nesse contexto. Por fim, o estudo **E18** propõe uma ontologia para modelar a jornada de interação e avaliar riscos de privacidade em aeroportos inteligentes. A ontologia analisa como dados pessoais são capturados e utilizados nesses ambientes, representando os riscos conforme o comportamento dos passageiros. Essa abordagem contribui para a proteção da privacidade e para a construção de ambientes digitais mais seguros e confiáveis.

Na dimensão das **Tecnologias**, destacam-se ontologias de segurança organizadas nas seguintes categorias:

- **Desenvolvimento de Frameworks**: O estudo **E1** propõe um framework para Sistemas de Gestão de Segurança da Informação (SIEM) baseado em uma ontologia de dupla camada, integrando conceitos das normas ISO 27000. Essa abordagem soluciona inconsistências presentes na ISO 27002 por meio da padronização de dados com o uso da *Basic Formal Ontology* (BFO) e da linguagem OWL, promovendo maior consistência e interoperabilidade entre os componentes do sistema. O estudo **E2** apresenta o STRAM (*Security, Trust, Resilience, and Agility Metrics*), um framework ontológico que quantifica a confiabilidade de sistemas computacionais a partir de quatro dimensões interrelacionadas: segurança, confiança, resiliência e agilidade. As métricas são organizadas de forma hierárquica, e o modelo possui aplicação prática na avaliação de sistemas e no planejamento de estratégias baseadas no cálculo quantitativo de submétricas. Já o estudo **E4** realiza uma sistematização de frameworks ontológicos aplicáveis à família de normas ISO/IEC 27000. Além de recomendar ontologias específicas para cada norma, o estudo identifica lacunas relevantes para futuras pesquisas em modelagem de riscos, ampliando as possibilidades de aplicação da ontologia no contexto normativo. O estudo **E5** aborda frameworks especializados, destacando o D3FEND, voltado à definição de contramedidas de cibersegurança, e o IoTSec, projetado para a segurança em ambientes de Internet das Coisas (IoT) industriais. Este último apresenta uma estrutura ontológica robusta com 228 classes, cobrindo aspectos de segurança em ambientes operacionais críticos, o que o torna altamente relevante para setores industriais. No estudo **E7**, é proposto o sCuDO, um framework ontológico baseado na Teoria Multi-Nível e na Ontologia UFO. O objetivo é realizar a classificação de ataques por meio da integração de taxonomias consolidadas do domínio de segurança, oferecendo uma estrutura analítica capaz de representar múltiplos níveis de abstração em cenários de ataque. Avançando na direção da automação, o estudo **E9** propõe um método para a geração de ontologias genéricas a partir de dicionários especializados, resultando em uma estrutura ontológica

com 2518 conceitos. Essa ontologia genérica pode ser reutilizada como base para o desenvolvimento de soluções específicas, acelerando o processo de construção ontológica. Por fim, os estudos **E15** (APKOWL) e **E13** complementam esse espectro com frameworks voltados à detecção de malware e à classificação de ontologias, respectivamente. O APKOWL aplica técnicas de engenharia reversa para construir ontologias a partir de aplicativos móveis, enquanto o estudo E13 foca na categorização e organização de ontologias de segurança. Juntos, esses estudos demonstram uma evolução contínua desde abordagens teóricas até aplicações práticas e automatizadas em segurança cibernética.

- **Ferramentas e Automação**: O estudo **E1** destaca o uso do editor de ontologias Protégé — desenvolvido pela Universidade de Stanford — como base para construção de uma ontologia de domínio de segurança alinhada à norma ISO. O estudo **E10** complementa essa abordagem, utilizando, além do Protégé, o yEd Graph Editor Manual como ferramenta gráfica para visualização e manipulação de grafos ontológicos. O estudo **E12** apresenta um guia prático para construção de ontologias em OWL, empregando o Protégé 4 em conjunto com as ferramentas CO-ODE (Collaborative Ontology Design Environment) — um conjunto de plugins desenvolvidos pela Universidade de Manchester que facilitam a modelagem colaborativa de ontologias em OWL por meio de recursos avançados de edição e validação. No estudo **E13**, os autores implementam a ontologia CRATELO (Context-aware Rule-based Adaptive Trust framework for Edge and Fog Computing Environments using Logic-based Ontologies) em OWL e SWRL, utilizando o Protégé para permitir raciocínio automatizado sobre confiança em ambientes de Edge Computing. O estudo **E15** demonstra uma abordagem para detecção de malware que combina regras SWRL (Semantic Web Rule Language) com o motor de inferência Jess (Java Expert System Shell), permitindo a derivação automatizada de intenções maliciosas a partir de ontologias de segurança. Nesta abordagem, as regras SWRL capturam padrões comportamentais de malware, enquanto o Jess executa essas regras de forma eficiente para gerar conclusões. O estudo **E16** apresenta um sistema que gera automaticamente estratégias de ataque baseadas em múltiplas vulnerabilidades, utilizando um grafo de conhecimento de domínio que relaciona vulnerabilidades, exploits e alvos potenciais. O estudo **E17** apresenta o sistema VALARIN para análise automatizada de arquivos PDF, combinando um pipeline de processamento com múltiplos parsers especializados, uma ontologia OWL desenvolvida no *Protégé* para classificação de malware, e métodos semi-automatizados para geração e fusão de ontologias. Este sistema utiliza, na detecção de PDFs maliciosos, abordagens híbridas que integram: (i) automação no processamento por meio de parsers; (ii) avaliação baseada na ontologia principal construída no Protégé; e (iii) intervenção humana especializada para validação final e refinamento das ontologias secundárias. Essa arquitetura permite análise em larga escala, mantendo a precisão na classificação de ameaças, com a ontologia atuando como núcleo de conhecimento para decisões automatizadas e os especialistas garantindo a atualização contínua do sistema. Por sua vez, o estudo **E19** apresenta uma abordagem inovadora para o desenvolvimento automático de ontologias na área de segurança da informação, utilizando técnicas de Processamento de Linguagem Natural (PLN) para extração de conceitos a partir de corpora textuais. A metodologia emprega múltiplos algoritmos de mineração de conhecimento e integra o yEd Graph Editor para visualização e manipulação dos grafos ontológicos gerados. Essa solução oferece ganhos significativos de produtividade, permitindo que especialistas concentrem seus esforços na validação e refinamento das ontologias, em vez de sua construção manual. Como estudo de caso, os autores demonstram a aplicação prática do modelo na criação automática de ontologias

para detecção e isolamento de falhas em sistemas automotivos em cenários reais.

- **Padronização e Qualidade**: Os estudos analisados demonstram forte integração com normas internacionais, especialmente aquelas pertencentes à família ISO. O estudo **E1** apresenta a modelagem de uma ontologia de domínio de segurança baseada nas normas ISO/IEC 27000 e ISO/IEC 27001, estabelecendo uma estrutura formal alinhada às melhores práticas de gestão da segurança da informação. Complementarmente, o estudo **E2** aborda os fundamentos necessários para compreender a estrutura de métricas de qualidade de sistemas, referenciando as normas ISO/IEC 9126 e ISO/IEC 25000 no contexto da avaliação da qualidade de produtos de software. No mesmo escopo de padronização, o estudo **E4** apresenta um conjunto de recomendações para o uso de ontologias específicas associadas aos diferentes padrões da série ISO/IEC 27k, reforçando a importância da adaptação ontológica conforme cada norma. Avançando para uma aplicação prática, o estudo **E5** propõe e desenvolve a Rantology, uma ontologia dedicada à detecção de extorsões digitais. A lógica codificada nesta ontologia permite avaliar a maliciosidade de programas com base em múltiplos componentes, sendo que os resultados obtidos confirmam sua adequação segundo critérios consolidados de qualidade. O estudo **E10** descreve o processo de criação de ontologias com o apoio das metodologias Methontology e IDEF5, buscando garantir a estruturação e a qualidade do produto ontológico final. Em uma abordagem mais integradora, o estudo **E12** destaca a aplicação de múltiplas ontologias no escopo da norma ISO/IEC 27032, evidenciando seu papel essencial na padronização da interoperabilidade entre sistemas de segurança da informação. Por último, o estudo **E13** propõe um framework para a caracterização conceitual de ontologias voltadas à segurança cibernética, com o objetivo de oferecer uma base homogênea, clara e bem definida para a comparação entre diferentes ontologias e suas conceituações. Esse framework adere aos princípios *FAIR* (Findability, Accessibility, Interoperability, and Reuse) aplicáveis a ativos digitais, e apresenta um procedimento composto por cinco etapas, permitindo a classificação de ontologias de acordo com níveis ortogonais de categorização, assegurando maior consistência nas análises comparativas.

Tabela 5. Distribuição dos estudos pelas dimensões fundamentais em SI e subcategorias identificadas nos estudos analisados.

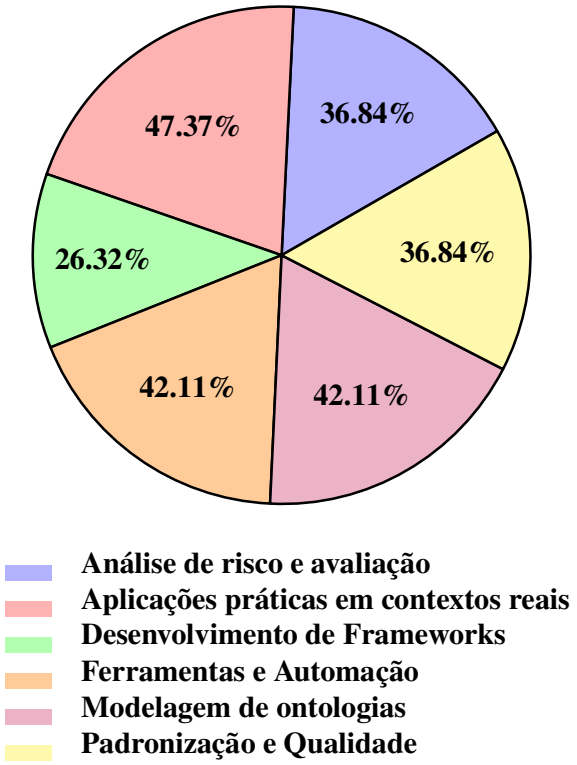
Dimensão de SI	Subcategoria	Estudos
Processos	Análise de risco e avaliação	E1, E2, E4, E10, E11, E13, E18
	Modelagem de ontologias	E1, E4, E5, E8, E9, E10, E12, E15, E17
Pessoas	Aplicações práticas em contextos reais	E5, E8, E15, E17, E18
Tecnologias	Desenvolvimento de Frameworks	E1, E2, E4, E5, E7, E9, E13, E16
	Ferramentas e Automação	E1, E5, E10, E12, E13, E15, E17, E19
	Padronização e Qualidade	E1, E2, E4, E5, E10, E12, E13

A **Tabela** 5 exibe a distribuição dos estudos segundo as dimensões fundamentais de SI e suas subcategorias, identificadas na análise.

Na **Figura** 4, apresenta-se a distribuição percentual dos estudos por subcategoria dentro

das dimensões de SI.

Figura 4. Distribuição percentual dos estudos por subcategorias nas dimensões de SI.



Taxonomia: Uso de Ontologias de Segurança em SI (Sub-Q1)

Com base na análise sistemática dos estudos selecionados (Sub-Q1), propõe-se uma taxonomia multidimensional organizada nas três dimensões fundamentais em Sistemas de Informação (SI):

1. Dimensão: Pessoas

- **1.1. Aplicações práticas em contextos reais**
  - APKOWL para detecção de malware SMS em Android. (E15)
  - Ontologia de domínio para engenharia social e análise de ataques. (E8)
  - Ontologia para modelar riscos de privacidade em aeroportos inteligentes. (E18)
  - Sistema VALARIN para análise de PDFs maliciosos. (E17)
  - Uso da ontologia Rantology para segurança digital. (E5)

2. Dimensão: Processos

- **2.1. Análise de risco e avaliação**
  - Análise de riscos para mensuração da confiabilidade de sistemas. (E2)
  - Avaliação de riscos de privacidade em aeroportos inteligentes. (E18)
  - Base fundamental em SGSI, com a norma ISO/IEC 27001. (E1)
  - Desenvolvimento da Ontologia de Segurança Combinada (CSO). (E10)
  - Framework de gestão de riscos baseado na ISO/IEC 27005. (E13)
  - Modelo para avaliação de riscos de ataques APT. (E11)
  - Ontologias de segurança aplicadas à ISO 27005. (E4)

- **2.2. Modelagem de ontologias**
  - Definição de relações e implementação de ontologia de domínio. (E8)
  - Design e implementação da ontologia Rantology. (E5)
  - Estrutura multi-ontológica para ameaças cibernéticas. (E12)
  - Implementação da CSO usando diagramas UML. (E10)
  - Método APKOWL para construção de ontologia OWL de malwares. (E15)
  - Método automático para design de ontologia genérica. (E9)
  - Modelo de ontologia para gestão de documentos em SGSI. (E1)
  - Ontologia OWL para interpretar arquivos PDF. (E17)

3. Dimensão: Tecnologia

- **3.1. Desenvolvimento de Frameworks**
  - Framework para classificação de ontologias de segurança. (E13)
  - Framework para SGSI baseado em ontologia de dupla camada. (E1)
  - Frameworks especializados, como D3FEND e IoTSec. (E5)
  - STRAM, framework ontológico para quantificar a confiabilidade. (E2)
  - sCuDO, framework baseado na Teoria Multi-Nível. (E7)
  - Sistema para gerar estratégias de ataque baseadas em vulnerabilidades. (E16)
  - Método para geração de ontologias genéricas. (E9)
- **3.2. Ferramentas e Automação**
  - Combinação de regras SWRL com motor de inferência Jess. (E15)
  - Desenvolvimento automático de ontologias com PLN. (E19)
  - Ontologia CRATELO para raciocínio automatizado em Edge Computing. (E13)
  - Ontologia para raciocínio automático e inferência. (E12)
  - Protégé e yEd Graph Editor para visualização de grafos. (E10)
  - Protégé para construção de ontologias. (E1)
  - Sistema VALARIN para análise de PDFs maliciosos com ontologias. (E17)
  - Sistema para gerar estratégias de ataque em larga escala. (E16)
- **3.3. Padronização e Qualidade**
  - Aplicação de ontologias no escopo da ISO/IEC 27032. (E12)
  - Framework para a caracterização de ontologias de segurança cibernética. (E13)
  - Ontologia de segurança baseada nas normas ISO/IEC 27000. (E1)
  - Ontologia Rantology e avaliação de qualidade. (E5)
  - Qualidade de sistemas com base nas normas ISO/IEC 9126. (E2)
  - Recomendações para ontologias aplicadas à série ISO/IEC 27k. (E4)
  - Uso das metodologias Methontology e IDEF5 na criação de ontologias. (E10)

***Sub-Q2**: Como é avaliado o desempenho das ontologias de segurança considerando as dimensões fundamentais em SI?*

A avaliação de desempenho de ontologias de segurança é condicionada por três componentes determinantes: (i) o conjunto de tecnologias empregadas, (ii) os objetivos específicos de cada implementação, e (iii) o contexto de aplicação. A análise dos estudos revisados permitiu categorizar sistematicamente as abordagens de avaliação segundo as dimensões clássicas de SI: **Processos**, **Pessoas** e **Tecnologias** [Laudon e Laudon 2020].

Na dimensão **Processos**, as avaliações concentram-se em aspectos conceituais, estruturais e metodológicos das ontologias. Destaca-se a **análise ontológica e de desempenho** presente no estudo **E1**, que explora o uso de ontologias para modelar padrões de segurança, como

a ISO/IEC 27001 e 27002, com o objetivo de formalizar o conhecimento e apoiar a análise e otimização dos processos de gestão da segurança da informação. Além disso, é introduzida uma ontologia baseada na ISO, utilizando o BFO para promover a interoperabilidade entre diferentes domínios. O estudo **E2** propõe a estrutura STRAM, composta por sub-ontologias para segurança, confiança, resiliência e agilidade, com o intuito de formalizar e avaliar o desempenho de sistemas em diversas dimensões, utilizando abordagens de modelagem, análise e experimentação. No mesmo contexto, o estudo **E5** apresenta uma ontologia voltada para o domínio de ransomware, evidenciando como a modelagem ontológica pode contribuir para o entendimento e mitigação de impactos em processos de sistemas de informação. Já o estudo **E6** propõe o uso de ontologias para estruturar conhecimentos de aprendizagem não formal e informal na área de segurança da informação, contribuindo para a descrição e análise dos processos de SI. Também se destaca o estudo **E7**, que desenvolve a ontologia *sCuDO*, baseada na Teoria Multinível (MLT) e na Ontologia Fundacional Unificada (UFO), com o objetivo de modelar incidentes de segurança da informação, tornar os conceitos mais explícitos e apoiar a gestão de processos de incidentes. O estudo **E10** discute metodologias para o desenvolvimento de ontologias aplicáveis à segurança da informação, ressaltando a importância da formalização explícita para o suporte a processos e sistemas baseados em conhecimento. O estudo **E12** apresenta uma estrutura multi-ontológica, composta pela ISTGO, ISTDO e ISTAO, para modelagem de ameaças em sistemas de informação, aplicando análise ontológica para resolver problemas de ambiguidade e incompletude nos processos de segurança. Por fim, o estudo **E18** utiliza o modelo *AttTucker*, adotando métricas como *F1-score* e precisão para mensurar a qualidade dos grafos de conhecimento, evidenciando o impacto da análise de caminhos entre entidades no desempenho de processos relacionados à segurança da informação.

Ainda nessa dimensão, destacam-se as **metodologias de avaliação**, como no estudo **E2**, que propõe a estrutura de métricas baseada em ontologia (STRAM) para medir a *trustworthiness* de sistemas. Esta abordagem inclui atributos fundamentais como segurança, confiança, resiliência e agilidade. O estudo classifica os métodos de medição em dois tipos principais: os baseados em modelagem/análise (tais como modelos estocásticos e simulação) e os baseados em experimentos, proporcionando uma metodologia robusta para avaliar diversos aspectos dos processos de SI. Em sequência, o estudo **E4** discute a certificação ISO/IEC 27001, com ênfase no processo de auditoria e avaliação da conformidade dos processos de gestão da segurança da informação com os requisitos da norma. Além disso, o estudo utiliza métricas para o mapeamento de padrões de segurança baseados em ontologia. No que se refere à **validação do desempenho em segurança**, também relacionada à dimensão Processos, o estudo **E4** analisa riscos com base em táticas, técnicas, vulnerabilidades e probabilidades de sucesso de ataques. O estudo **E7** aplica estudos de caso para validar o framework multiontologia ISTMOF, voltado à modelagem de ameaças. Complementando esse contexto, o estudo **E8** realiza uma revisão sistemática de métricas, com foco na aplicabilidade de submétricas de segurança. O estudo **E12** adota um processo iterativo de refinamento contínuo, utilizando cenários ilustrativos para testar a aplicabilidade da ontologia. Também, o estudo **E13** apresenta um *framework* para a classificação de ontologias, oferecendo uma abordagem metodológica para analisar o estado das ontologias no domínio da segurança da informação. Essa ferramenta se mostra útil também na avaliação da formalização e da estrutura dos processos de SI. Por fim, o estudo **E14** valida a ontologia *sCuDO* com dados reais, demonstrando sua aplicabilidade e robustez em comparação com abordagens não ontológicas.

Na dimensão **Pessoas**, predominam as **avaliações práticas e testes de usabilidade**, com foco em aplicação em cenários reais. O estudo **E2** propõe o framework STRAM, que mede a confiabilidade de sistemas computacionais, levando em conta componentes humanos

como usabilidade, *desempenho* e satisfação. Ele também destaca ferramentas de avaliação que envolve a simulação de ataques por pessoas para identificar vulnerabilidades no sistema. Já o estudo **E5** descreve a ontologia Rantology voltada para ataques de ransomware. Tal ontologia é avaliada com base em critérios como clareza, modularidade, consistência e cobertura, sendo a clareza especialmente relevante para garantir a compreensão por parte dos usuários. O estudo **E6** propõe o uso de thesauri de tarefas baseados em ontologias para associar resultados de aprendizagem a descrições de tarefas no domínio da segurança da informação. A validação do processo de aprendizagem envolve a comparação de competências descritas em linguagem natural com descrições formalizadas, o que serve como uma forma prática de avaliar a aplicabilidade do conhecimento das pessoas. O estudo **E8**, por sua vez, aborda o desenvolvimento de uma ontologia para engenharia social, sugerindo que sua avaliação deve ser feita por meio de métodos de resolução de problemas ou aplicando-a em cenários de ataques de engenharia social, envolvendo a compreensão do comportamento humano em contextos de segurança. No estudo **E12**, é proposta uma estrutura multi-ontológica para o modelo de ameaças de sistemas de informação (ISTMOF), sugerindo que essa estrutura pode orientar profissionais de segurança que exigem habilidades especializadas e prática contínua. O estudo **E18** detalha o desenvolvimento da IJPRA, uma ontologia voltada para aeroportos inteligentes, que foi avaliada por meio de cenários de análise de riscos de privacidade, com a realização de sessões de revisão para garantir a qualidade e relevância dos cenários, representando, assim, uma avaliação da usabilidade da ontologia. Finalmente, estudo **E19** avalia conteúdo e usabilidade em cenários de ataques, analisando também desempenho na detecção de ameaças.

Na dimensão **Tecnologias**, destacam-se as seguintes categorias:

- **Avaliações Quantitativas com Métricas de Desempenho** O estudo **E2** propõe o framework STRAM para medir a qualidade de sistemas computacionais, considerando diversos aspectos tecnológicos e **métricas de desempenho** para avaliar ferramentas de avaliação. O estudo **E5** descreve o desenvolvimento e a avaliação da Rantology, uma ontologia para ataques de ransomware. A avaliação envolve diferentes abordagens, incluindo a comparação com um padrão de ouro, com uma fonte de dados, o uso em uma aplicação e a avaliação manual por especialistas. A qualidade da Rantology também é medida com base em **métricas de esquema** fornecidas pelo OntoQA. A capacidade de raciocínio da ontologia é testada para verificar a **subsunção** e a **consistência**, e a sua capacidade de responder a questões de competência é também avaliada. O estudo **E8** afirma que a melhor forma de avaliar a qualidade de uma ontologia desenvolvida é por meio de **métodos de resolução de problemas** ou utilizando-a em **aplicações reais**. A ontologia de engenharia social é avaliada por meio da sua aplicação na análise de cenários de ataques.
- **Validações Baseadas em Critérios de Qualidade** O estudo **E2** considera atributos como **consistência**, **completude**, **usabilidade**, **testes de implementação** e **feedback de especialistas**. O estudo **E3** aplica critérios de **completude**, **validade** e **aplicabilidade**, alinhando-se a revisões sistemáticas. O estudo **E10** avalia a integração da ontologia com **normas ISO/IEC 27000** e sua **cobertura conceitual**. O estudo **E15** valida o framework em contextos comerciais (Accenture LTD), comparando **abordagens manuais e automatizadas** com base em **esforço**, **tempo** e **custo**.

Dessa forma, observa-se que a avaliação das ontologias de segurança em SI é multidimensional, sendo conduzida com base na natureza da proposta e alinhando-se às dimensões de Processos, Pessoas e Tecnologias. As abordagens vão desde análises conceituais e estruturais até testes empíricos e métricas quantitativas, refletindo a complexidade e a diversidade dos

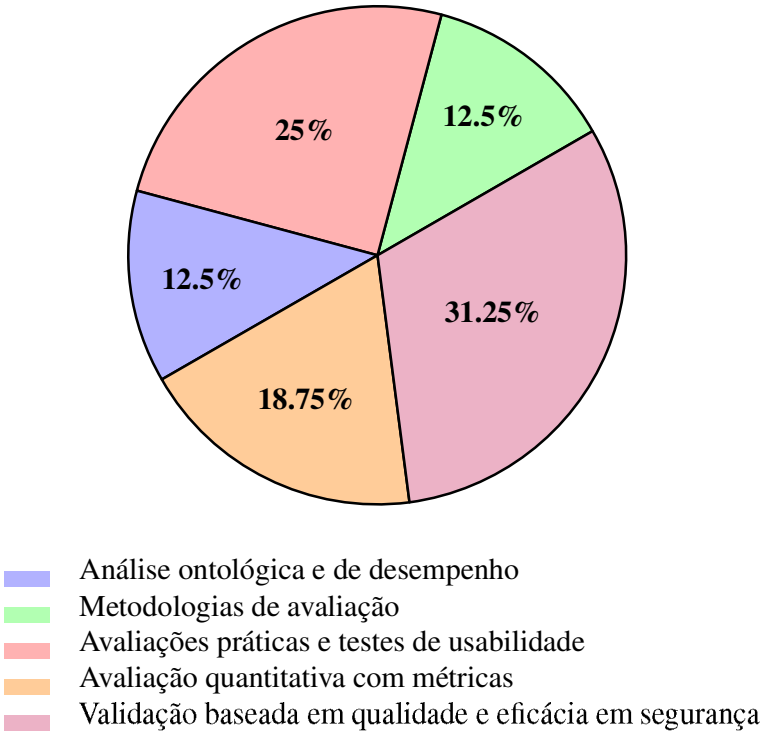
contextos de aplicação.

A **Tabela 6** apresenta a distribuição dos estudos analisados segundo as dimensões fundamentais de SI e suas respectivas subcategorias. E na **Figura 5**, é apresentada a distribuição percentual dos estudos segundo os métodos de avaliação nas dimensões de SI.

Tabela 6. Distribuição dos estudos nas dimensões fundamentais em SI e pelas subcategorias identificadas nos estudos analisados.

Dimensão de SI	Subcategoria	Estudos
Processos	Análise ontológica e de desempenho	E1, E2, E5, E6, E7, E10, E12, E18
	Metodologias de avaliação	E2, E4, E7, E12, E13, E14
	Validação do desempenho em segurança	E4, E7, E8, E12, E13, E14
Pessoas	Avaliações práticas e testes de usabilidade	E2, E5, E6, E8, E12, E18, E19
Tecnologias	Avaliações Quantitativas com Métricas de Desempenho	E2, E5, E8
	Validações Baseadas em Critérios de Qualidade	E2, E3, E10, E15

Figura 5. Distribuição percentual dos estudos por subcategorias nas dimensões de SI.



Taxonomia: Avaliação de Ontologias de Segurança em SI (Sub-Q2)

Com base na análise sistemática dos estudos selecionados (Sub-Q2), propõe-se uma taxonomia multidimensional organizada nas três dimesões fundamentais em SI:

1. Dimensão: Pessoas

- **1.1. Avaliações práticas e testes de usabilidade**
  - Avaliação da ontologia de engenharia social em cenários reais. **(E8)**
  - Clareza e aplicabilidade da ontologia Rantology. **(E5)**
  - Testes de desempenho em cenários de ataques. **(E19)**
  - Validação da ontologia de tarefas e aprendizagem em segurança. **(E6)**

2. Dimensão: Processos

- **2.1. Análise ontológica e de desempenho**
  - Avaliação de grafos de conhecimento. **(E18)**
  - Avaliação de desempenho usando STRAM. **(E2)**
  - Modelagem de incidentes de segurança com *sCuDO*. **(E7)**
  - Modelagem de padrões de segurança (ISO/IEC 27001 e 27002). **(E1)**
- **2.2. Metodologias de avaliação**
  - Auditoria e conformidade com ISO/IEC 27001. **(E4)**
  - Framework para classificação de ontologias. **(E13)**
  - Refinamento contínuo de multi-ontologias. **(E12)**
  - Revisão sistemática sobre métricas de segurança. **(E8)**
  - Validação de ISTMOF em estudos de caso. **(E7)**

3. Dimensão: Tecnologias

- **3.1. Avaliação quantitativa com métricas**
  - Avaliação da ontologia Rantology com métricas de OntoQA. **(E5)**
  - Avaliação de grafos de conhecimento em segurança. **(E18)**
  - Métricas de desempenho no STRAM. **(E2)**
  - Avaliação da ontologia de engenharia social em ataques. **(E8)**
- **3.2. Validação baseada em qualidade e eficácia em segurança**
  - Análise de consistência e completude de ontologias. **(E12)**
  - Avaliação de ontologias em segurança da informação. **(E13)**
  - Validação da ontologia STRAM com normas ISO/IEC 27000. **(E2)**
  - Validação em contexto comercial, comparando abordagens. **(E15)**
  - Avaliação da ontologia conforme normas ISO/IEC 27001. **(E10)**

***Sub-Q3**: Quais componentes impactam o desenvolvimento e aplicação dessas ontologias em cada dimensão de SI?*

Esta questão teve como objetivo identificar os componentes das ontologias de segurança que apresentam aderência às normas e melhores práticas reconhecidas, bem como sua capacidade de integração com outros padrões e sistemas em SI [Szyperski 2002][Sommerville 2016a]. Nos estudos analisados, destacaram-se diversos componentes principais: **Normas e Integração de Ontologias, Avaliação de Riscos e Ameaças, Aspectos Técnicos de Implementação e Aspectos Humanos e Comportamentais**.

Os componentes podem ser agrupados de acordo com as dimensões em Sistemas de Informação: **Tecnologias**, **Processos** e **Pessoas**.

Esta questão teve como objetivo identificar os componentes das ontologias de segurança que apresentam aderência às normas e melhores práticas reconhecidas, bem como sua capacidade de integração com outros padrões e sistemas em SI [Szyperski 2002][Sommerville 2016a]. Nos estudos analisados, destacaram-se diversos componentes principais: **Normas e Integração de Ontologias, Avaliação de Riscos e Ameaças, Aspectos Técnicos de Implementação e Aspectos Humanos e Comportamentais**.

Os componentes podem ser agrupados de acordo com as dimensões de SI que são Tecnologias, Processos e Pessoas.

Na dimensão Tecnologias, incluem-se os componentes:

Normas e Integração de Ontologias e Aspecto Técnicos de Implementação. Em relação às **Normas e Integração de Ontologias**, o foco está em garantir a conformidade das ontologias de segurança com normas reconhecidas, bem como em sua capacidade de integração com outros padrões e sistemas existentes. O estudo **E1** destaca a utilização de uma abordagem ontológica de dupla camada para modelar Sistemas de Gestão de Segurança da Informação (SIEMs), visando aprimorar tanto a segurança quanto a conformidade com normas, como a ISO 27000. A camada superior adota a *Basic Formal Ontology* (BFO), promovendo a interoperabilidade entre diferentes domínios, enquanto a camada específica modela detalhadamente as normas ISO. O principal objetivo é otimizar a gestão do ciclo de vida de documentos e práticas de segurança da informação, facilitando auditorias e certificações, como a ISO/IEC 27001.No estudo **E2**, é apresentada uma revisão e comparação das ontologias de segurança baseadas na série de normas ISO/IEC 27000, destacando o uso da tecnologia ontológica como uma ferramenta eficaz para vincular conceitos de segurança às normas. A análise leva em consideração diversos aspectos, como a integração com outras normas, as metodologias adotadas, as linguagens utilizadas e as lacunas conceituais presentes nas ontologias. O estudo **E7** descreve a criação de um fragmento de ontologia de domínio sobre incidentes de segurança da informação, utilizando a *Unified Foundational Ontology* (UFO) e a *Multi-Level Theory* (MLT). Este estudo visa aprimorar a clareza conceitual e a interoperabilidade. A MLT complementa a UFO ao permitir a definição de relações entre diferentes níveis de classificação, enquanto a UFO fornece uma base sólida e formalmente estruturada para representar conceitos do mundo real. A combinação UFO-MLT estabelece padrões úteis para o desenvolvimento de ontologias empresariais específicas, funcionando como uma base conceitual robusta. O estudo **E10** aborda os desafios enfrentados no alinhamento e comparação de ontologias, como a incompletude e as diferenças de modelagem entre domínios. Para superar essas limitações, foi proposta a **CSO** (Ontologia de Segurança Combinada), baseada na UFO, com o objetivo de unificar terminologias e facilitar a interoperabilidade entre os domínios de segurança da informação e segurança física. A CSO foi mapeada para diversas normas de segurança, como ISO/IEC 27001, NIST e PCI DSS, com o intuito de reduzir a complexidade, apoiar a gestão e aprimorar a tomada de decisões. O estudo **E10** também apresenta um framework de *modelagem de ameaças baseado em múltiplas ontologias*, visando resolver problemas comuns nos métodos existentes, como ambiguidade, heterogeneidade, incompletude e fragmentação de modelos em diferentes níveis de abstração. O framework é composto por três camadas: uma *ontologia generalizada* (GO), uma *ontologia de domínio* (DO) e uma *ontologia de aplicação* (AO), todas baseadas em padrões como *ISO/IEC 27032* e *MITRE ATT&CK*. O estudo **E13** propõe um **Framework para Classificação de Ontologias** com foco na cibersegurança, fundamentado em princípios ontológicos que visam melhorar a **interoperabilidade semântica** entre diferentes modelos. O framework aborda a importância do *Compromisso Ontológico* para clarificar o significado dos construtos em linguagens de modelagem e contribuir para atingir os princípios **FAIR** (*Findability, Acces-*

sibility, Interoperability, and Reuse) de ativos digitais. Esse modelo classifica ontologias de acordo com seu nível (ontologias fundamentais e de domínio) e aplicação (ontologias referenciais e operacionais), proporcionando uma base homogênea para comparações. Além disso, o framework considera a **validação e verificação terminológica** com base em normas reconhecidas, como ISO/IEC 27032 e 27000, estendendo e padronizando vocabulários. A análise das **relações entre ontologias** permite identificar subontologias, sobreposição de domínios e o uso de ontologias fundamentais comuns. A análise cruzada do conceito de "Risco" revela que diferentes ontologias (como SECCO, COoVR e a baseada na ISO/IEC 27005) apresentam divergências conceituais, evidenciando que **a interoperabilidade não pode ser garantida apenas por similaridade estrutural**, sendo necessária uma compreensão ontológica profunda. O estudo enfatiza que **a ambiguidade e a complexidade do domínio da cibersegurança exigem uma fundamentação ontológica robusta** para possibilitar a integração e reutilização eficaz do conhecimento. Por fim, o estudo **E18** apresenta a ontologia IJPRA (Integrated Interaction Journey and Privacy Risk Assessment), que integra as ontologias IJ (Interaction Journey) e PR (Privacy Risk), utilizando a norma NIST 800-30 como base para a integração. A ontologia IJPRA relaciona o processo de avaliação de risco de privacidade com ativos, riscos de privacidade, requisitos e controles, mapeando esses conceitos para os da UFO.

Aspectos Técnicos de Implementação: o foco está nos métodos e ferramentas para construir, representar formalmente, fundamentar e avaliar ontologias e sistemas baseados em ontologias. O estudo **E1** propõe o uso de ontologias como um instrumento poderoso para que computadores não apenas armazenem ou recuperem informações, mas também sejam capazes de interpretá-las. A abordagem consiste em modelar padrões específicos por meio de uma estrutura ontológica, permitindo que os sistemas computacionais atuem como consumidores ativos de informação. A representação de padrões particulares é tratada através de ontologias de domínio em um nível mais detalhado. As terminologias utilizadas buscam conformidade com padrões estabelecidos por organizações como o *National Institute of Standards and Technology* (NIST) e a ISO, que promovem a ordenação do conhecimento técnico-científico em nível conceitual, servindo como base para a modelagem técnica. O software *Protégé* é citado como uma ferramenta relevante nesse contexto.

O estudo **E2** apresenta o framework *STRAM*, voltado à medição da confiabilidade de sistemas computacionais, com base em uma estrutura hierárquica de ontologias. Cada submétrica—Segurança, Confiança, Resiliência e Agilidade—é representada como uma subontologia. As ontologias formais são codificadas em linguagens legíveis por máquina, como a *Web Ontology Language* (OWL), formando assim ontologias computacionais. A ferramenta *Protégé* foi empregada no desenvolvimento da ontologia proposta. As medições podem ser realizadas com base em modelagem e análise, utilizando métodos como modelos estocásticos, simulação e emulação, ou por meio de experimentos. O framework propõe a inclusão de métricas relacionadas a ferramentas-chave de avaliação, como análise de vulnerabilidades, análise de risco e *Red Teaming*, reforçando a importância de métodos e ferramentas de avaliação.

O estudo **E3** adota uma perspectiva tecnológica, envolvendo a construção de modelos e algoritmos com base ontológica. São enfatizadas decisões arquiteturais e tecnológicas no desenvolvimento de um sistema complexo, com implementação da ontologia integrada à base de conhecimento. A linguagem *SPARQL* é utilizada para formalização de consultas, destacando-se por seu alto grau de maturidade e versatilidade. Também é proposto o desenvolvimento de um pacote de software para gerenciamento de riscos e prevenção de ameaças. Além disso, é descrito um método técnico para identificação de usuários com base em padrões de interação na internet.

O estudo **E4** realiza uma comparação entre ontologias com base em critérios como linguagem e ferramentas de desenvolvimento, destacando implementações em OWL, RDF e DAML. A análise considera características formais (*ABox*) e conceituais (*TBox*), níveis de axiomatização e a expressividade da linguagem adotada. Ontologias baseadas em normas ISO 27001, 27002 e 27005 são apresentadas como exemplos práticos de formalização normativa.

O estudo **E5** descreve a aplicação de ontologias na análise de *malware*, utilizando DAML+OIL e o sistema de raciocínio DAMLJessKB. O framework ontológico emprega *machine learning* para examinar redes complexas de relações. Termos são extraídos de arquivos *manifest* de aplicativos, e representações semânticas são construídas com auxílio da UCO Ontology e bases como DBpedia e YAGO. Os dados são armazenados em triplas RDF. A ontologia é implementada em OWL, com definição de classes, propriedades e instâncias. O raciocinador *FaCT++* é usado para verificar subsunção e consistência. O Protégé permite consultas via *Description Logic*. A avaliação da ontologia baseia-se em comparação com padrões de referência e uso prático, sendo adotados frameworks como o OntoQA.

O estudo **E6** busca formalizar o conhecimento em cibersegurança por meio de ontologias, visando sua legibilidade por máquinas, automação de operações e intercâmbio eficiente de informações. Propõe-se o uso de tesauros baseados em ontologias para integração e correspondência entre domínios. A semântica de recursos como a Wikipédia é processada via análise ontológica, com geração automática de representações. As tecnologias da Web Semântica são referenciadas como essenciais para o acesso baseado em conhecimento.

O estudo **E7** aplica ontologias em modelos conceituais para incidentes de segurança da informação. São discutidas representações em nível de instância e tipologias, com uso da *Unified Foundational Ontology* (UFO), abrangendo aspectos estruturais (UFO-A), temporais (UFO-B) e sociais (UFO-C). A linguagem SPARQL é mencionada para consultas semânticas.

O estudo **E8** descreve a construção de uma ontologia no domínio da engenharia social, utilizando o método de Noy e McGuinness com adaptações. O Protégé 5.5.0 foi a ferramenta empregada. Classes e propriedades são modeladas com uso de *Description Logic*, incluindo a categorização de ataques.

O estudo **E9** aborda a geração automática de ontologias a partir de fontes de dados textuais, destacando a economia de tempo e esforço. Métodos como *clustering* (MARCOV, *Fuzzy c-means*) e técnicas de Processamento de Linguagem Natural (NLP) são utilizados para extrair conceitos e atributos.

O estudo **E10** trata da Ontologia de Segurança Combinada (CSO), cuja formalização foi realizada por meio de diagramas UML. A metodologia Methontology foi aplicada, incluindo etapas como especificação, conceituação, formalização, integração e implementação, combinada com outro método para facilitar o reuso.

O estudo **E12** apresenta um framework de multiontologia (GO, DO, AO), construído com seleção ponderada de conceitos e mapeamentos entre classes. A proposta serve como guia técnico em atividades como testes de penetração e análise de ameaças. Diagramas UML são utilizados para modelagem conceitual.

O estudo **E13** investiga a aplicação de *Knowledge Graphs* (KGs) como ontologias operacionais. Destacam-se decisões de projeto, linguagem e metodologia de implementação como determinantes na expressividade e axiomatização. A Metodologia Design Science é aplicada. O estudo propõe uma solução de *backend* para facilitar a análise cruzada e classificação de dados.

O estudo **E14** descreve o sistema APKOWL, voltado à detecção automática de *malware*

em nível de design, baseado em engenharia reversa de aplicativos móveis. A ontologia OWL é construída automaticamente em Python e Protégé. A implementação foi realizada em PyCharm e Google Colab, sendo avaliada por métricas como acurácia, precisão e *recall*.

O estudo **E16** aborda o uso de ontologias e *Knowledge Graphs* em cibersegurança, com aplicações em áreas como forense digital. Representações gráficas e mapeamento ontológico são utilizados para análise, com a ferramenta Neo4j-D3-VKG sendo referenciada.

O estudo **E18** trata do desenvolvimento da ontologia IJPRA por meio da integração de outras ontologias. A modelagem gráfica é usada na representação de conceitos e relacionamentos. O banco de dados de grafo Neo4j é especificado para representar instâncias ontológicas.

Na dimensão Processos, tem-se o componente **Avaliação de Riscos e Ameaças**, cujo foco está na identificação, análise e mitigação dos riscos e ameaças à segurança em SI, considerando tanto os aspectos técnicos quanto os humanos. O estudo **E1** aborda auditoria e certificação e o uso de ontologias de segurança para apoiar a certificação ISO/IEC 27001. Também explora o mapeamento de padrões de segurança, como a ISO 27002, para estruturas ontológicas. No estudo **E2**, é abordada a avaliação de interconexões entre diferentes componentes de segurança e os riscos associados. A ontologia permite mapear as interações entre vulnerabilidades, ameaças e defesas, o que é fundamental para avaliar a segurança de forma holística e identificar pontos críticos de falha. No estudo **E3**, destaca-se o uso de fontes internas e externas de dados para uma visão holística do risco cibernético. A ontologia deve integrar dados provenientes de diversas fontes internas e externas para proporcionar uma análise mais precisa e abrangente dos riscos cibernéticos. No estudo **E10**, é abordada a abordagem de causas e consequências de riscos de segurança e ameaças. O modelo de ontologia mapeia os riscos e suas consequências, considerando as relações entre os diferentes componentes de segurança. Isso permite uma visão detalhada de como as ameaças podem impactar os sistemas. O estudo **E11** foca na identificação de componentes de ataque, risco e requisitos de segurança para ataques APT. A ontologia considera as táticas, técnicas e procedimentos (TTPs) de ataques avançados (APT), além de avaliar as vulnerabilidades e as medidas de segurança necessárias para mitigar esses riscos. O estudo **E13** é dedicado à caracterização e classificação de ontologias no domínio da cibersegurança. Ele inclui e discute de forma explícita a *Common Ontology of Value and Risk* (COoVR) e a ontologia da norma ISO/IEC 27005:2011, sendo esta última uma norma específica para a gestão de riscos da segurança da informação. O documento realiza uma análise ontológica aprofundada dos conceitos de *Risco* e *Avaliação de Risco*, discutindo como as ontologias podem ser utilizadas para modelar o domínio de valor e risco, bem como os processos de gestão de riscos. O estudo **E14** apresenta o desenvolvimento de uma ontologia chamada **ContSOnto**, baseada na norma ISO 13940 para apoiar a continuidade do cuidado em sistemas de saúde. A ontologia visa garantir fluxos de estudo de dados seguros e confiáveis, promovendo a integridade e a consistência das informações ao longo do processo de cuidado. O estudo **E15** concentra-se no processo de detecção de ransomware no nível de design, por meio da ontologia **APKOWL**, construída a partir da engenharia reversa de aplicativos móveis. O processo envolve a modelagem da estrutura e do comportamento do malware, simulando suas interações com o sistema, como chamadas de API. Essa análise detalhada do processo de execução da ameaça permite sua identificação e mitigação, além de possibilitar o reconhecimento de malware APT com base em representações ontológicas. O estudo **E18** trata da avaliação de riscos relacionados à privacidade em ambientes de aeroportos inteligentes. A ontologia ajuda a analisar os riscos de privacidade associados ao uso de tecnologias em aeroportos, com foco na proteção de dados pessoais dos passageiros. Por fim, o estudo **E19** analisa a qualidade dos dados e conflitos em grafos de conhecimento de cibersegurança. A ontologia deve avaliar a qualidade dos dados utilizados na construção de

grafos de conhecimento, levando em conta a presença de ruídos ou conflitos que possam afetar a precisão das análises de segurança.

Na dimensão Pessoas, os componentes **Aspectos Humanos e Comportamentais** referem-se ao impacto do comportamento humano e dos fatores sociais sobre a segurança em Sistemas de Informação (SI).

O **estudo E2** apresenta o framework *STRAM*, desenvolvido para mensurar a confiabilidade de sistemas de segurança por meio de uma estrutura baseada em ontologias. Embora o foco principal esteja na modelagem da arquitetura do sistema e nas métricas associadas, o estudo reconhece a relevância da dimensão humana ao incorporar os "fatores humanos" como um dos componentes a serem avaliados. Além disso, faz referência a estudos prévios que modelam aspectos comportamentais, como o impacto de traços de personalidade na confiança e na suscetibilidade a ataques de *phishing*, evidenciando a importância da representação técnica desses elementos no domínio da segurança cibernética.

O **estudo E5** também ressalta a relevância dos aspectos humanos e comportamentais, incluindo a conscientização situacional e o papel do comportamento do usuário na gestão de riscos e na segurança. A ontologia desenvolvida incorpora explicitamente a dimensão "Pessoas", por meio de classes como *Atacante* e *Vítima*, além de discutir como esses fatores são essenciais para uma compreensão abrangente da segurança cibernética no contexto ontológico.

O **estudo E7** aborda a classificação e priorização de incidentes com base no impacto organizacional e no comportamento dos participantes. A ontologia proposta organiza os incidentes de segurança de maneira a priorizar aqueles com maior impacto, considerando as ações humanas envolvidas em sua ocorrência.

Por fim, o **estudo E8** dedica-se integralmente à construção de uma ontologia de domínio voltada à engenharia social, com ênfase na modelagem e categorização de vulnerabilidades humanas — elementos centrais nesse tipo de ataque. Tais vulnerabilidades são descritas em dimensões como cognição/conhecimento, comportamento/hábito, emoção/sentimento e aspectos psicológicos, incluindo traços de personalidade, natureza humana e caráter individual. O estudo destaca a influência crítica de fatores humanos, como comportamentos suscetíveis e julgamentos equivocados, que podem ser explorados por agentes maliciosos em campanhas de engenharia social. A ontologia desenvolvida contempla esses componentes humanos, definindo formalmente conceitos, classes e relações semânticas que permitem representar tais aspectos de maneira estruturada, promovendo uma abordagem sistemática à dimensão "Pessoas" no contexto da segurança da informação.

Na **Tabela 7**, são apresentados a distribuição dos estudos pelas dimensões fundamentais em SI e subcategorias identificadas nos estudos analisados.

Na **Figura 6**, é apresentada a distribuição percentual dos estudos pelas subcategorias identificadas nos estudos analisados.

Tabela 7. Distribuição dos estudos nas dimensões fundamentais em SI e pelas subcategorias identificadas nos estudos analisados

Dimensão de SI	Subcategoria	Estudos
Tecnologias	Normas e Integração de Ontologias	E1, E2, E7, E10, E13, E18
	Aspectos Técnicos de Implementação	E1, E2, E3, E4, E5, E6, E7, E8, E9, E10, E12, E13, E14, E16, E18
Processos	Avaliação de Riscos e Ameaças	E1, E2, E3, E10, E11, E13, E14, E15, E18, E19
Pessoas	Aspectos Humanos e Comportamentais	E2, E5, E7, E8

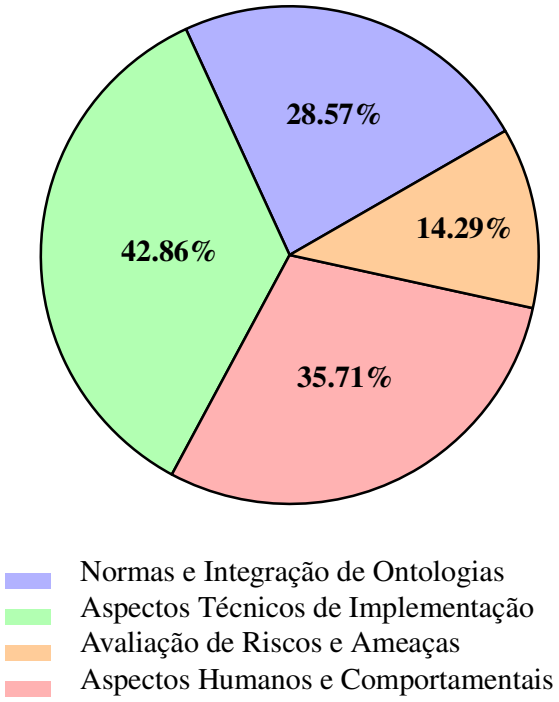


Figura 6. Distribuição percentual dos estudos nas dimensões de SI

Taxonomia: Avaliação de Ontologias de Segurança em SI (Sub-Q3)

Com base na análise sistemática dos estudos selecionados, propõe-se uma taxonomia multidimensional organizada nas três dimensões fundamentais em Sistemas de Informação:

1. Dimensão de Tecnologias

1.1. Normas e Integração de Ontologias

- Conformidade com normas reconhecidas (ISO/IEC 27000, NIST, PCI DSS) **(E1, E2, E7, E10, E13, E18)**
- Integração com padrões e sistemas existentes **(E1, E2, E7, E10, E13, E18)**
- Interoperabilidade semântica entre domínios **(E1, E2, E7, E10, E13, E18)**

- Modelagem de múltiplas camadas (BFO, UFO, MLT) **(E1, E7, E10)**
- Validação terminológica baseada em normas **(E13, E18)**

1.2. Aspectos Técnicos de Implementação

- Ferramentas de desenvolvimento (Protégé, Neo4j) **(E1, E2, E4, E5, E8, E14)**
- Frameworks ontológicos (STRAM, CSO, IJPRA) **(E2, E10, E18)**
- Métodos formais de representação (OWL, RDF, SPARQL) **(E1-E10, E12-E14, E16, E18)**
- Processamento automatizado e machine learning **(E5, E6, E9, E14)**
- Técnicas de engenharia ontológica **(E3, E6, E9, E12)**

2. Dimensão de Processos

2.1. Avaliação de Riscos e Ameaças

- Análise holística de vulnerabilidades **(E2, E3, E10, E11)**
- Avaliação de qualidade de dados **(E19)**
- Gestão do ciclo de vida de segurança **(E1, E13)**
- Mapeamento de riscos e suas consequências **(E1-E3, E10, E11, E13, E15, E18, E19)**
- Modelagem de ameaças (APT, ransomware) **(E11, E15)**
- Processos de certificação e auditoria **(E1, E13)**

3. Dimensão de Pessoas

3.1. Aspectos Humanos e Comportamentais

- Classificação de incidentes baseada em fatores humanos **(E7)**
- Conscientização situacional **(E5, E7)**
- Engenharia social e fatores psicológicos **(E8)**
- Impacto do comportamento do usuário **(E2, E5, E7, E8)**
- Modelagem de vulnerabilidades humanas **(E2, E5, E7, E8)**

6. Conclusão

Este RSL investiga o uso de ontologias de segurança em SI, destacando sua crescente importância diante do avanço da digitalização e da interconexão de sistemas como SoS, CPS e Sistemas Inteligentes. A revisão identificou 19 estudos publicados a partir de 2019, que abordam uma ampla variedade de métodos, técnicas, modelos e ferramentas voltados à segurança da informação por meio de ontologias.

As ontologias demonstram um bom **desempenho** na unificação de dados heterogêneos, na superação de ambiguidades conceituais e no fortalecimento da governança da informação. Sua aplicação se dá em três dimensões fundamentais dos SI: **Processos**, **Pessoas** e **Tecnologias**. No âmbito dos **processos**, destacam-se aplicações voltadas à análise e avaliação de riscos, bem como à gestão de incidentes. Na dimensão das **pessoas**, evidenciam-se abordagens que consideram aspectos humanos e comportamentais, como os ataques de engenharia social. Já na dimensão **tecnológica**, observam-se avanços em frameworks, automação e integração com ferramentas e normas de segurança, promovendo interoperabilidade e resposta a ameaças emergentes.

O RSL também evidencia uma variedade de abordagens para a **avaliação das ontologias**, incluindo análises ontológicas, testes práticos, métricas quantitativas e validações baseadas em critérios de qualidade e usabilidade. Essa avaliação é essencial para garantir o **desempenho** e a adaptabilidade das soluções em contextos reais. Outro ponto relevante é a **integração**

das ontologias com normas reconhecidas, como as normas ISO, assegurando conformidade e facilitando a interoperabilidade com outros sistemas.

Como resultado dos estudos abordadfos, propõe-se uma **taxonomia multidimensional**, organizada pelas três dimensões (Processos, Pessoas e Tecnologias) e suas respectivas subcategorias, com base nas questões de pesquisa levantadas por este RSL. As três taxonomias oferecem uma visão integrada e holística sobre o uso de ontologias de segurança em SI. Dessa forma, tais taxonomias servirão de base para o desenvolvimento futuro de uma **taxonomia integrada** e, posteriormente, de uma **ontologia extensível e reutilizável** no domínio da segurança da informação em SI.

Referências

Aboshady, D., Ghannam, N. E., Elsayed, E. K., e Diab, L. S. (2023). Apkowl: An automatic approach to enhance the malware detection. *Mobile Networks and Applications*, pp. 1–12.

Adach, M., Hänninen, K., e Lundqvist, K. (2022). A combined security ontology based on the unified foundational ontology. In *2022 IEEE 16th International Conference on Semantic Computing (ICSC)*, pp. 187–194.

Aganette, E., Alvarenga, L., e Souza, R. (2010). Definições e aplicações de taxonomia em organizações. *Revista de Gestão da Informação*, 5:45–60.

Alabsi, M., Gill, A., e Bandara, M. (2024). Integrated interaction journey and privacy risk assessment: A graph model. *Procedia Computer Science*, 239:1594–1603. CENTERIS – International Conference on ENTERprise Information Systems / ProjMAN - International Conference on Project MANagement / HCist - International Conference on Health and Social Care Information Systems and Technologies 2023.

Belani, H., Šolić, P., Perković, T., e Zovko, K. (2023). Ontology-based cybersecurity for well-being, aging and health: A scoping review. In *2023 IEEE International Mediterranean Conference on Communications and Networking (MeditCom)*, pp. 50–55.

Brasileiro, , Jesus, J., Santos, J. C., Schiessl, M., Oliveira, K., Costa, L., Fujita, M., Castro, P., Gomes, R., Menêses, R., e Moreira, W. (2019). *Guia do usuário do TemaTres*.

Campos, M. L. A. e Gomes, H. E. (2008). *Taxonomia Corporativa: Métodos e Práticas*. Editora ABC, São Paulo.

Casola, V., Catelli, R., e De Benedictis, A. (2019). A first step towards an iso-based information security domain ontology. In *2019 IEEE 28th International Conference on Enabling Technologies: Infrastructure for Collaborative Enterprises (WETICE)*, pp. 334–339.

Cho, J.-H., Xu, S., Hurley, P. M., Mackay, M., Benjamin, T., e Beaumont, M. (2019). Stram: Measuring the trustworthiness of computer-based systems. *ACM Comput. Surv.*, 51(6).

Dyba, T., Dingsoyr, T., e Hanssen, G. K. (2007). Applying systematic reviews to diverse study types: An experience report. In *ESEM 2007*, pp. 225–234.

Faria, M. R., de Figueiredo, G. B., de Faria Cordeiro, K., Cavalcanti, M. C. R., e Campos, M. L. M. (2019). Applying multi-level theory to an information security incident domain ontology. In *ONTOBRAS*.

Ghazani, S. H. H. N., Lotf, J. J., e Aliguliyev, R. (2012). A study on qos models for mobile ad-hoc networks. *International Journal of Modeling and Optimization*, 2(5):634.

Hu, X., Cheng, D., Chen, J., Jin, X., e Wu, B. (2022). Multiontology construction and application of threat model based on adversarial attack and defense under iso/iec 27032. *IEEE Access*, 10:117955–117972.

ISO (2013). *ISO/IEC 27002:2013 - Information technology — Security techniques — Code of practice for information security controls*. International Organization for Standardization.

Keshavarzi, M. e Ghaffary, H. R. (2023). An ontology-driven framework for knowledge representation of digital extortion attacks. *Computers in Human Behavior*, 139:107520.

Kitchenham, B. e Charters, S. (2007). Guidelines for performing systematic literature reviews in software engineering. Technical Report EBSE 2007-001, Keele University and Durham University Joint Report.

Lam, D., Li, L., e Anderson, C. (2024). Pdf investigation with parser differentials and ontology. *Trans. Info. For. Sec.*, 19:7774–7782.

Laudon, K. C. e Laudon, J. P. (2020). *Management Information Systems: Managing the Digital Firm*. Pearson, Harlow, England, 16th edition.

Li, H., Shi, Z., Pan, C., Zhao, D., e Sun, N. (2023). Cybersecurity knowledge graphs construction and quality assessment. *Complex & Intelligent Systems*, 10:1201–1217.

Maier, M. W. (1998). Architecting principles for systems-of-systems. *Systems Engineering*, 1(4):267–284.

Malagutti, M. A. O. (2016). O papel da dissuasão no tocante a ofensas cibernéticas. *Doutrina Militar Terrestre em Revista*, 4(9):18–27.

Martins, B. F., Gil, L. J. S., Román, J. F. R., Panach, J. I., Pastor, Ó., Hadad, M., e Rochwerger, B. (2022). A framework for conceptual characterization of ontologies and its application in the cybersecurity domain. *Software and Systems Modeling*, 21:1437 – 1464.

Meriah, I. e Arfa Rabai, L. B. (2019). Comparative study of ontologies based iso 27000 series security standards. *Procedia Computer Science*, 160:85–92. The 10th International Conference on Emerging Ubiquitous Systems and Pervasive Networks (EUSPN-2019) / The 9th International Conference on Current and Future Trends of Information and Communication Technologies in Healthcare (ICTH-2019) / Affiliated Workshops.

Meriah, I., Rabai, L. B. A., e Khedri, R. (2021). Towards an automatic approach to the design of a generic ontology for information security. In *2021 Reconciling Data Analytics, Automation, Privacy, and Security: A Big Data Challenge (RDAAPS)*, pp. 1–8.

Niyazova, R., Aktayeva, A., e Davletkireeva, L. (2019). An ontology based model for user profile building using social network. In *Proceedings of the 5th International Conference on Engineering and MIS*, ICEMIS '19, New York, NY, USA. Association for Computing Machinery.

Noy, N. e Mcguinness, D. (2001). Ontology development 101: A guide to creating your first ontology. *Knowledge Systems Laboratory*, 32.

Park, S.-H. e Lee, S.-W. (2022). Threat-driven risk assessment for apt attacks using risk-aware problem domain ontology. In *2022 IEEE 30th International Requirements Engineering Conference Workshops (REW)*, pp. 226–231.

Rogushina, J. V., Gladun, A. Y., Pryima, S. M., e Strokan, O. V. (2019). Ontology-based approach to validation of learning outcomes for information security domain. In *International Conference on Intelligent Tutoring Systems*.

Russell e Norvig, S. (2010). Artificial intelligence: A modern approach. *Prentice Hall, Englewood Cliffs, NJ*.

Sikos, L. F. (2023). Cybersecurity knowledge graphs. *Knowledge and Information Systems*, 65:3511–3531.

Sommerville, I. (2016a). *Software Engineering*. Pearson, Boston, 10th edition.

Sommerville, I. (2016b). *Software Engineering, 10th Edition*. Pearson.

Studer, R., Benjamins, V. R., e Fensel, D. (1998). Knowledge engineering: Principles and methods. *Data & Knowledge Engineering*, 25(1-2):161–197.

Szyperski, C. (2002). *Component Software: Beyond Object-Oriented Programming*. Addison-Wesley, Boston, 2nd edition.

Wang, Z., Zhu, H., Liu, P., e Sun, L. (2021). Social engineering in cybersecurity: a domain ontology and knowledge graph application examples. *Cybersecurity*, 4.

Whitman, M. E. e Mattord, H. J. (2009). *Principles of information security*. Thompson Course Technology, 3 edition.

Zeadally, S. e Jabeur, N. (2016). *Cyber-physical system design with sensor networking technologies*. Institution of Engineering and Technology.